

QuoteCraft Architecture Review

Executive Summary

- QuoteCraft is a Silver-tier internal microservice handling Restricted data (PII + Financial), deployed on AlphaPaaS (AWS) with cross-cloud dependencies on Azure and AWS managed services.
- Multiple critical gaps exist in security and availability, including improper secrets handling, lack of multi-AZ resilience for core data stores, and exposure misconfiguration.
- Cost controls are breached in non-production environments and storage lifecycle, with excessive spend and lack of cold storage transitions.
- Scalability is limited by in-memory rate limiting and single-replica deployments, risking service degradation at forecasted peak loads.
- Remediation actions are clearly identified and should be prioritized for backlog inclusion.

Findings

Cost

F-01: Non-production environment exceeds cost threshold

- Severity: Critical
- Dimension: Cost
- Evidence:
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "QuoteCraft's non-production environment is consuming approximately 35% of what production consumes. The cause has not been investigated."
- Policy reference: FIN-07
- Why it matters: Exceeding the 20% threshold triggers a FinOps review and risks budget overruns.
- Remediation: Investigate non-production resource sizing and scheduling; reduce spend to $\leq 20\%$ of production.
- Confidence: High

F-02: EFS provisioned throughput waste

- Severity: High
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/efs.tf
- Quote: "Provisioned throughput. Originally set during the pilot when we thought PDF generation would be I/O bound. It isn't. Tracked in QC-211."
- Policy reference: FIN-06
- Why it matters: Unnecessary provisioned throughput increases monthly storage costs.
- Remediation: Switch EFS to standard throughput mode unless documented IOPS requirement exists.
- Confidence: High

F-03: S3 archive lacks lifecycle policy for cold storage

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/s3.tf
- Quote: "No lifecycle configuration. Quote archives are kept in STANDARD storage class indefinitely. There was a ticket to add glacier transition (QC-134) but it was deprioritised."
- Policy reference: FIN-13
- Why it matters: Keeping archives in standard storage increases long-term costs.
- Remediation: Implement S3 lifecycle policy to transition archives to Glacier after 30 days.
- Confidence: High

F-04: Application logs retention exceeds Silver tier requirement

- Severity: Low
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/cloudwatch.tf
- Quote: "retention_in_days = 365"
- Policy reference: FIN-16
- Why it matters: 365-day retention is for Gold tier; Silver tier requires 90 days, leading to unnecessary log storage costs.
- Remediation: Reduce application log retention to 90 days for Silver tier workloads.
- Confidence: High

Security

F-05: Secrets exposed as environment variables

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "envFrom: ... secretRef: ... AWS_ACCESS_KEY_ID ... valueFrom: secretKeyRef"
- Policy reference: CKS-11, DCH-07

- Why it matters: Secrets in environment variables risk disclosure via logs, dumps, and process listings.
- Remediation: Refactor deployment manifests to mount secrets as file volumes using CSI driver or External Secrets Operator.
- Confidence: High

F-06: Use of long-lived IAM user access keys

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/secret-aws-keys.yaml
- Quote: "Long-lived IAM user access keys for reading from AWS Secrets Manager and mounting EFS. Created by the initial platform onboarding."
- Policy reference: AHS-11, ASC-06
- Why it matters: Long-lived credentials are prohibited; workload identity federation is required for cloud API access.
- Remediation: Migrate to IRSA (IAM Roles for Service Accounts) for AWS access; decommission IAM user keys.
- Confidence: High

F-07: External API calls with certificate verification disabled

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/integrations/bureau.py
- Quote: "verify=False ... TODO(QC-189): migrate to verify=True once the Atlas production CA is added to the base image trust store."
- Policy reference: DCH-05
- Why it matters: Disabling certificate verification exposes the service to man-in-the-middle attacks.
- Remediation: Add Atlas CA to trust store and enable certificate verification for bureau API calls.
- Confidence: High

F-08: Public network access enabled for Azure PostgreSQL

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:infra/azure/postgres.tf
- Quote: "public_network_access_enabled = true"
- Policy reference: ASC-03, AHS-15
- Why it matters: Public access increases attack surface and breaches private connectivity requirements.
- Remediation: Disable public network access for Azure PostgreSQL; ensure all traffic routes via Private Endpoint.
- Confidence: High

F-09: Role with wildcard permissions

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/rbac.yaml
- Quote: "apiGroups: [\"*\"], resources: [\"*\"], verbs: [\"*\"]"
- Policy reference: CKS-14
- Why it matters: Wildcard permissions violate least privilege and CIS benchmark requirements.
- Remediation: Restrict Role permissions to only required resources and verbs.
- Confidence: High

F-10: Redis transit encryption disabled

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "transit_encryption_enabled = false"
- Policy reference: ASC-03, ASC-05
- Why it matters: Lack of TLS exposes session cache and rate limiter state to potential interception.
- Remediation: Enable transit encryption for ElastiCache Redis and update application to use rediss://.
- Confidence: High

Scalability

F-11: In-memory rate limiter not horizontally scalable

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/middleware/rate_limit.py
- Quote: "Module-level singleton; NOT shared across pods. ... horizontal scaling will be addressed in QC-201."
- Policy reference: ARS-14
- Why it matters: Rate limiting is enforced per pod, leading to quota breaches and false positives when scaled.
- Remediation: Externalize rate limiter state to Redis or another distributed store to support horizontal scaling.
- Confidence: High

F-12: Single-replica deployment in production manifest

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "replicas: 1"
- Policy reference: ARS-03, ARS-13
- Why it matters: Silver tier requires minimum 3 replicas and HPA for baseline load; single replica limits throughput and resilience.
- Remediation: Update deployment to minimum 3 replicas and configure HorizontalPodAutoscaler.
- Confidence: High

F-13: Database connection pool not implemented

- Severity: Medium
- Dimension: Scalability

- Evidence:
- Source: app:src/quotecraft/db.py
- Quote: "TODO(QC-142): migrate to psycopg_pool.ConnectionPool ... For now we open a connection per request"
- Policy reference: ARS-06
- Why it matters: Opening a new connection per request risks exhaustion and degraded performance at peak load.
- Remediation: Implement connection pooling for Postgres.
- Confidence: High

Availability

F-14: Azure PostgreSQL lacks zone-redundant high availability

- Severity: Critical
- Dimension: Availability
- Evidence:
- Source: app:infra/azure/postgres.tf
- Quote: "Zone-redundant HA is not configured. ... The HA configuration has not yet been revisited since the initial pilot."
- Policy reference: ARS-18, ASC (Azure DB for Postgres)
- Why it matters: Single-AZ database breaches Silver tier requirement for AZ resilience; risks data loss and downtime.
- Remediation: Enable zone-redundant high availability for Azure PostgreSQL Flexible Server.
- Confidence: High

F-15: ElastiCache Redis deployed as single-AZ, no replication

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "Nodes: 1 (single-AZ)"
- Policy reference: ARS-18, ASC (ElastiCache Redis)

- Why it matters: Single-AZ cache risks loss of session and rate limiter state during AZ failure.
- Remediation: Deploy ElastiCache Redis as a multi-AZ replication group.
- Confidence: High

F-16: Disaster recovery exercise not performed

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "DR exercise: **not yet performed.** Scheduled for Q3 2026."
- Policy reference: ARS-20
- Why it matters: Silver tier requires annual DR exercise; lack of testing means recovery procedures are unverified.
- Remediation: Schedule and execute DR exercise simulating AZ loss; document outcome in runbook.
- Confidence: High

F-17: Route exposure misconfiguration

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/route.yaml
- Quote: "router: external"
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "Exposure Internal only — intended router label: router=irp"
- Policy reference: AHS-05
- Why it matters: Route is labelled as external, but intake form specifies internal-only exposure; this is a material security and availability finding.
- Remediation: Correct Route manifest to router=irp for internal exposure.
- Confidence: High

F-18: Use of deprecated DeploymentConfig resource

- Severity: Medium

- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/worker-deploymentconfig.yaml
- Quote: "kind: DeploymentConfig"
- Policy reference: ARS-03, ARS-23
- Why it matters: DeploymentConfig is deprecated for Silver tier; migration to Deployment required by end of Q4 2026.
- Remediation: Migrate worker deployment to apps/v1 Deployment resource.
- Confidence: High

Highest Priority Next Actions

1. Refactor secrets handling to mount secrets as file volumes, eliminating environment variable exposure (CKS-11, DCH-07).
2. Migrate AWS access to workload identity federation (IRSA), decommission long-lived IAM user keys (AHS-11, ASC-06).
3. Enable zone-redundant high availability for Azure PostgreSQL Flexible Server (ARS-18).
4. Correct Route manifest to router=irp for internal exposure, matching intake form (AHS-05).
5. Investigate and reduce non-production environment spend to $\leq 20\%$ of production (FIN-07).

All findings are grounded in the cited evidence and AlphaPaaS policy clauses. Contradictory or missing evidence is noted where relevant. Remediation steps are actionable and suitable for backlog inclusion.